

KIT INTEGRAL DE EVALUACIÓN DE MADUREZ CIBERSEGURIDAD

Sistema Completo de Encuesta + GQM + PRAGMATIC para Organizaciones Españolas

Versión: 2.0 Consolidada

Fecha: Enero 2026

Clasificación: Uso Interno - Confidencial

Propósito: Consolidación de 7 documentos profesionales para evaluación de ciberseguridad alineada con CIS Controls v8.1, NIST CSF 2.0, NIS2, GDPR, ISO 27001, y regulaciones españolas

ÍNDICE MAESTRO DEL KIT COMPLETO

DOCUMENTOS ORIGINALES (Fase 1)

[144] DOCUMENTO A: *Modelo de Encuesta Integral*

Archivo: Encuesta-Integral-Ciberseguridad.md

Contenido:

-  **8 módulos temáticos** completos (GRC, IDENTIFY, IAM, PROTECT/DETECT/RESPOND, CONTINUITY, CYBER_RISK, SCRM)
-  **140+ preguntas discriminatorias** estructuradas en escala 1-5 (Ad Hoc — Optimizado)
-  **Escala de madurez contextualizada** con descripciones literarias de cada nivel
-  **Matriz de agregación** para cálculo de puntuaciones
-  **Validación de evidencia** requerida por tipo de control
-  **Adaptación específica** para PYME, empresa crítica, y administración pública
-  **Tono irónico pero profesional** en redacción de preguntas

Uso Recomendado: Encuesta base a distribuir entre responsables de seguridad (tiempo: 45-60 minutos)

Público Objetivo: CISO, Security Managers, IT Directors, Compliance Officers

[145] DOCUMENTO B: *Guía Metodológica Detallada*

Archivo: Guia-Metodologica-Aplicacion-Analisis.md

Contenido:

-  **Protocolo de administración** (cronograma 10-12 semanas)
-  **Instrucciones para respondentes** (cómo rellenar encuesta)
-  **Protocolos de calibración** para asegurar objetividad (sesiones grupales)
-  **Reglas de puntuación estrictas** con ejemplos de interpretación
-  **Metodología de análisis** (gap analysis, tendencias, benchmarking)
-  **Plantillas de reportes ejecutivos** (8-12 páginas)
-  **Gráficos recomendados** (radar charts, funciones NIST, comparativas)

-  **FAQ esperadas de Board** con respuestas calibradas
-  **KPIs de seguimiento** post-evaluación
-  **Benchmarks sectoriales** España 2024-2025 (Financiero, Energía, Tech, PMEs, Admin Pública)

Uso Recomendado: Manual operacional durante ejecución (referencia continua cada semana)

Público Objetivo: CISO, analistas de seguridad, auditores internos, consultores

[146] DOCUMENTO C: *Narrativa Explicativa*

Archivo: Narrativa-Explicativa-Tono-Ironico.md

Contenido:

-  **Filosofía de comunicación** (ironía afectuosa sin culpa)
-  **Estructura narrativa** "Scaffolded" para cada pregunta
-  **Las 5 "personas ficticias"** en cada nivel de madurez (El Improvisador → El Innovador)
-  **Decisiones lingüísticas** (español técnico con alma, sin anglicismos innecesarios)
-  **Humor español integrado** (irónico, literario, reconocedor)
-  **Estructura de viaje de 3 actos** (Gobernanza → Protección → Resiliencia)
-  **Metáforas recurrentes** (Brújula, Muro Vivo, Orquesta, Radar, etc.)
-  **Adaptaciones por contexto** (PYMEs, Crítica, Pública)
-  **Checklist de "tono válido"** para validación
-  **La encuesta como acto de liderazgo visible** (por qué medir, no es castigo)

Uso Recomendado: Leer PRIMERO para entender espíritu del marco (base conceptual); referencia durante implementación si hay duda sobre "tono"

Público Objetivo: CISO (para brief a equipo), comunicación interna, presentación a board

DOCUMENTOS COMPLEMENTARIOS (Fase 2)

[188] DOCUMENTO D: *Mapeo Detallado a Requisitos Normativos*

Archivo: Mapeo-Normativo-Indicadores.md

Contenido:

-  **Matriz exhaustiva** CIS Controls → NIST CSF 2.0 → NIS2 → GDPR → ISO 27001
-  **Regulaciones españolas** (INCIBE, CCN, ENS, LOPD-GDD)
-  **Artículos específicos** de cada normativa (ej: NIS2 Art. 20, GDPR Art. 32)
-  **Críticidad de cumplimiento** (CRÍTICO / ALTO / MEDIO / Recomendado)
-  **Obligatoriedad vs Voluntario** claramente marcado
-  **Notas sobre multas potenciales** por incumplimiento (€X rango)
-  **Resumen de criticidad por regulación** (cuál afecta a qué indicador)
-  **Observaciones importantes** por normativa (ej: NIS2 24h reporting)

Uso Recomendado: Validar qué normativas aplican a organización ANTES de ejecutar encuesta; usar como checklist de compliance

Público Objetivo: Legal, Compliance Officer, CISO, Audit Committee, Reguladores

[189] DOCUMENTO E: Plantilla Excel para Cálculo IGM & ROI

Archivo: Plantilla-IGM-ROI-Excel.md

Contenido:

-  **Estructura 6 hojas** (Instrucciones, Entrada datos, Cálculo IGM, Cálculo ROI, Dashboard, Benchmarks)
-  **Automatización de cálculos PRAGMATIC** (suma, promedio, percentiles)
-  **IGM (Índice Generación Métricas)** 0-100% con interpretación
-  **ROI ciberseguridad** modelo 3 años (Inversión vs Beneficios)
-  **Benchmarks sectoriales** España desglosados (Financiero 78%, Energía 81%, Tech 84%, PME 62%, Admin 71%)
-  **Posicionamiento competitivo** (cuartil Q1-Q4 vs sector)
-  **Análisis de sensibilidad** (si varían asunciones $\pm 20\%$)
-  **Breakeven point calculation** (cuándo se recupera inversión)
-  **Fórmulas Excel predefinidas** listas para copia/pega

Uso Recomendado: Post-encuesta; cálculos automáticos; presentación financiera a CFO/Board

Público Objetivo: CFO, Finance Team, CISO, Board Members

[190] DOCUMENTO F: Plantilla Reporte Ejecutivo PowerPoint

Archivo: Plantilla-Reporte-PowerPoint.md

Contenido:

-  **15-18 diapositivas** profesionales listas para personalizar
-  **Portada + Agenda**
-  **Estado ejecutivo** (resumen 30 segundos de posición actual)
-  **KPI Dashboard** (4 métricas clave con trending)
-  **Análisis IGM por módulo CIS** (gráfico barras horizontal)
-  **Análisis de vulnerabilidades** (con timeline)
-  **Respuesta a incidentes** (MTTD/MTTR análisis)
-  **Conciencia de seguridad** (phishing click rate trending)
-  **Benchmarking sectorial** (comparativa vs peers)
-  **Hallazgos críticos** (4-5 riesgos con priorización)
-  **Roadmap Q2-Q3 2026** (6 meses con hitos)
-  **Presupuesto & ROI** (inversión €X – retorno €Y)
-  **Recomendaciones para votación** (5 decisiones key)
-  **Governance continuo** (reporting frequency)
-  **Cierre & Q&A**
-  **Notas para presentador** (timing, tono, respuestas típicas)

Uso Recomendado: Presentación formal a Board/Audit Committee (25 min presentación + 5 min Q&A)

Público Objetivo: Board Members, C-Suite (CFO/COO/CIO), Audit Committee

[191] DOCUMENTO G: README del Kit de Encuesta

Archivo: README-Kit-Encuesta.md

Contenido:

-  **¿Qué es este kit?** (definición clara vs alternativas)
-  **Componentes del kit** (6 documentos + descripción cada uno)
-  **Cómo usar el kit** (roadmap de implementación 8-12 semanas)
 - Fase 0: Preparación (semanas 1-2)
 - Fase 1: Ejecución encuesta (semanas 3-5)
 - Fase 2: Reporte y presentación (semanas 6-8)
 - Fase 3: Monitoreo continuo (meses 3-12+)
-  **Mejores prácticas** (5 áreas clave)
 - Asegurar objetividad (no sesgo)
 - Comunicación clara (tono irónico)
 - Trazabilidad regulatoria
 - Involucración de ejecutivos
 - Plan de remediación
-  **FAQ** (7 preguntas típicas + respuestas)
-  **Contactos y soporte**
-  **Versionamiento y actualizaciones**
-  **Checklist de implementación**

Uso Recomendado: Referencia continua durante proyecto (12 meses mínimo); guía de troubleshooting

Público Objetivo: CISO, Project Manager, Security Team (todos los stakeholders)

[192] DOCUMENTO H: Matriz Evaluación PRAGMATIC Completa

Archivo: Matriz-Evaluacion-PRAGMATIC.md (NUEVO: complementa Documento D)

Contenido:

-  **45+ indicadores detallados** derivados de CIS Controls v8.1
-  **8 módulos temáticos** (GRC, IDENTIFY, IAM, PROTECT, DETECT, RESPOND, RECOVER, CYBER_RISK, SCRM)
-  **Evaluación exhaustiva PRAGMATIC** (9 criterios: Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable)
-  **Score total por indicador** (0-3 escala)
-  **Fichas técnicas completas** (fórmula, fuente datos, frecuencia, target, benchmark)
-  **Recomendación de implementación** ( IMPLEMENTAR /  CONDICIONAL /  RECHAZAR)
-  **Plan faseado** (Fase 1 rápida, Fase 2 medio, Fase 3 consolidación)
-  **Resumen de criticidad** por score PRAGMATIC

Uso Recomendado: Seleccionar indicadores específicos según fase; referencia técnica durante análisis

Público Objetivo: CISO, Metrics Team, Auditores, Risk Managers

ESTRUCTURA RECOMENDADA DE LECTURA

Para CISO/Líder Proyecto:

1. README (Documento G) - 30 min
 - └ Entender qué es el kit y roadmap general
2. Narrativa (Documento C) - 1 hora
 - └ Entender espíritu/tono de la encuesta
3. Mapeo Normativo (Documento D) - 1 hora
 - └ Validar qué regulaciones aplican
4. Guía Metodológica (Documento B) - 2 horas
 - └ Entender proceso de ejecución
5. Encuesta Integral (Documento A) - 1.5 horas
 - └ Familiarizarse con preguntas
6. Excel (Documento E) - 1 hora
 - └ Entender cálculos e interpretación
7. PowerPoint (Documento F) - 1 hora
 - └ Preparar presentación a board

Total: 7.5 horas de preparación

Para Respondentes (Responsables áreas):

1. Introducción del CISO (5 min) - sobre por qué se hace
2. Encuesta (60 min) - responder 140+ preguntas
3. Sesión de calibración (30 min) - aclarar respuestas con otros

Para Board/Ejecutivos:

1. Resumen de Narrativa (15 min)
2. Presentación PowerPoint (25 min)
3. Q&A (5 min)

MATRIZ DE ALINEACIÓN REGULATORIA

Documento	CIS v8.1	NIST CSF 2.0	NIS2	GDPR	ISO 27001	ENS España
A - Encuesta	✓✓✓	✓✓	✓✓	✓	✓✓	✓✓
B - Guía	✓✓	✓	✓	-	✓	✓✓
C - Narrativa	✓	-	-	-	-	✓
D - Mapeo Normativo	✓✓✓	✓✓✓	✓✓✓	✓✓✓	✓✓✓	✓✓✓
E - Excel IGM/ROI	✓✓	✓	-	-	✓	-
F - PowerPoint	✓	-	✓	-	-	-
G - README	✓	-	-	-	✓	✓
H - Matriz PRAGMATI C	✓✓✓	✓✓	✓✓	✓	✓✓	✓✓

ROADMAP IMPLEMENTACIÓN COMPLETA

Semana 1-2: PREPARACIÓN

- ☐ Descargar y revisar Documentos G, C, D
- ☐ Crear equipo de trabajo (CISO, Security Managers, Finance, Legal)
- ☐ Validar regulaciones que aplican (usando Documento D)
- ☐ Personalizar Documentos A y B a contexto organizacional

Semana 3-5: ENCUESTA

- ☐ Distribuir Documento A (Encuesta Integral)
- ☐ Usar Documento B como guía operacional
- ☐ Sesiones de calibración (Documento C como referencia de tono)
- ☐ Recopilar datos y validar

Semana 6: ANÁLISIS

- ☐ Introducir datos en Documento E (Excel)
- ☐ Calcular IGM automáticamente
- ☐ Comparar vs Documento H (Matriz PRAGMATIC)
- ☐ Identificar riesgos críticos

Semana 7-8: REPORTE

- ☐ Usar Documento F (PowerPoint template)
- ☐ Personalizar con datos finales
- ☐ Presentar a Board
- ☐ Obtener aprobación presupuesto

Mes 3-12: MONITOREO

- ☐ Implementar dashboard (usando Documento E)
- ☐ Reportes mensuales/trimestrales (usando Documento F template)
- ☐ Re-evaluaciones anuales (usando Documento A)
- ☐ Actualizaciones de benchmarks (usando Documento H)



INDICADORES CLAVE DE ÉXITO

- ✓ IGM baseline establecido (% conocido)
- ✓ Riesgos críticos identificados (<10 total)
- ✓ Plan de acción aprobado (presupuesto asignado)
- ✓ Dashboard vivo (data actualizada semanalmente)
- ✓ Tendencia IGM mejorando (+10% cada 12 meses)
- ✓ Board satisfecho con transparencia y acción
- ✓ Cumplimiento regulatorio demostrado (auditable)



CÓMO DESCARGAR LOS DOCUMENTOS

Opción 1: Descargar Individual

Cada documento tiene un ID de artifact (ej: [144], [145], etc.)

- Hacer clic en el ID
- Botón "Descargar" en esquina superior derecha
- Guardar como .md en tu máquina

Opción 2: Script Automático (Python)

```
# script_descargar_kit.py
import requests
import os

documentos = {
    "144": "Encuesta-Integral-Ciberseguridad.md",
    "145": "Guia-Metodologica-Aplicacion-Analisis.md",
    "146": "Narrativa-Explicativa-Tono-Ironico.md",
    "188": "Mapeo-Normativo-Indicadores.md",
    "189": "Plantilla-IGM-ROI-Excel.md",
    "190": "Plantilla-Reporte-PowerPoint.md",
    "191": "README-Kit-Encuesta.md",
    "192": "Matriz-Evaluacion-PRAGMATIC.md"
}

for artifact_id, filename in documentos.items():
    # Lógica de descarga aquí
    print(f"Descargando {filename}...")
```

Opción 3: Copiar-Pegar Manual

Cada documento es un archivo .md que puede:

- Copiarse a editor de texto (VS Code, Notepad++)
- Convertirse a Word/PDF
- Importarse a Google Docs
- Usarse directamente en Markdown viewers

DIFERENCIAL DE ESTE KIT

Vs Auditorías Externas:

-  Costo: €0 (gratuito) vs €50-100k de consultor
-  Tiempo: 8-12 semanas vs 16-20 semanas
-  Control: Interno vs externo observador
-  Continuidad: Repetible anualmente vs one-off

Vs Encuestas Genéricas:

-  Contexto: Específico España (regulaciones, idioma) vs genérico global
-  Metodología: GQM + PRAGMATIC (trazable + viable) vs ad-hoc
-  Tono: Irónico pero profesional (honesto) vs seco o marketing
-  Actionable: Métricas claras (no vanity) vs información vaga

Vs Frameworks Teóricos:

-  Práctico: Implementable hoy vs académico
-  Integrado: 7 documentos + roadmap vs solo marco
-  Traducido: Español fluido vs traducciones automatizadas
-  Financiero: ROI calculado vs solo risk mitigation

SOPORTE Y CONTACTOS

Si necesitas:

- **Preguntas metodológicas:** Consulta Documento B y G
- **Preguntas técnicas sobre indicadores:** Consulta Documento H
- **Preguntas normativas:** Consulta Documento D
- **Preguntas de tono/narrativa:** Consulta Documento C
- **Preguntas Excel/cálculos:** Consulta Documento E
- **Preguntas presentación:** Consulta Documento F

Escalación si bloqueado:

- CISO directo (tema urgente)
- Security Steering Committee (decisión needed)
- Board audit committee (aprobación needed)

CHECKLIST FINAL

PREPARACIÓN:

- ☐ Descargar todos 8 documentos (144-192)
- ☐ Asignar CISO como propietario del proyecto
- ☐ Crear equipo de trabajo multifuncional
- ☐ Validar regulaciones que aplican
- ☐ Obtener aprobación ejecutiva para presupuesto

EJECUCIÓN:

- ☐ Calendario de 8-12 semanas definido
- ☐ Encuesta personalizada y lista (Documento A)
- ☐ Instrucciones a respondentes (Documento B)
- ☐ Sesiones de calibración planeadas
- ☐ Excel preparado (Documento E)

ANÁLISIS:

- ☐ Datos recopilados y validados
- ☐ IGM calculado
- ☐ Riesgos identificados (prioritarios)
- ☐ Plan de remediación creado

REPORTE:

- ☐ PowerPoint personalizado (Documento F)
- ☐ Presentación ensayada
- ☐ Board citado
- ☐ Votación de recomendaciones

POST-REPORTE:

- ☐ Dashboard implementado
- ☐ Reporting frecuencia establecida (trimestral mínimo)
- ☐ Roadmap de mejora en progreso
- ☐ Re-evaluación anual planeada

KIT COMPLETO - ESTADO: LISTO PARA PRODUCCIÓN

Versión: 2.0 Consolidada

Fecha: Enero 2026

Documentos: 8 (Documentos A-H)

Páginas equivalentes: 180-220

Clasificación: Uso Interno

Idioma: Español (ES-ES)

¿Listo para comenzar tu evaluación de madurez ciberseguridad?

Todos los documentos están disponibles para descargar. Comienza con Documento G (README) para orientación general.

¡Éxito en tu proyecto!